



سياسة حماية البيانات الشخصية والخصوصية

09 أغسطس 2023م

1. سجل التعديلات على السياسة 3
2. سجل الاعتماد 3
3. بطاقة السياسة 4
4. المصطلحات والتعاريف 5
5. بنود السياسة 7
 - 5.1 حقوق أصحاب البيانات الشخصية 7
 - 5.2 البيانات الائتمانية والصحية: 10
 - 5.3 الاطفال ومن في حكمهم: 10
 - 5.4 معالجة البيانات وشفافية المخاطر: 11
 - 5.5 حوكمة البيانات الشخصية: 11
 - 5.6 الادوار والمسؤوليات: 13
 - 5.7 مراقبة الامتثال للسياسات: 13
 - 5.8 الاستثناءات من السياسة: 14
6. آلية إدارة تحديثات السياسة 15
 - 6.1 المراجعة الدورية 15
7. المراجع 15

1. سجل التعديلات على السياسة



رقم النسخة	مسؤول التغيير	التغييرات	تاريخ النسخة
V1.00	غيداء الديري	المسودة الأولية متزامنة مع ضوابط هيئة الامن السيبراني	01-Dec-2021
V2.00	منيرة الزهراني	1. تم تغيير ملكية السياسة من الإدارة العامة للأمن السيبراني والمعلوماتي الى إدارة مكتب البيانات 2. مراجعة اسم السياسة ومحتواها وتحديثهما لتتماشى مع ضوابط مكتب إدارة البيانات الوطنية والأنظمة ذات العلاقة المعمول بها في المملكة.	30-May-2023

2. سجل الاعتماد



الاسم	المنصب	التوقيع
عمر الجبري	مدير عام التميز المؤسسي	
فهد السوييس	مدير عام مكتب البيانات	
هيفاء الشعلان	وكيل المحافظ للتحليل والمخاطر	بالإنابة - فهد علي السوييس
انس العقلاء	نائب المحافظ للشؤون القانونية والالتزام	عنه / يوسف الهذلول
عبدالله الفتوخ	نائب المحافظ للاستراتيجية والتطوير	
سهيل ابانمي	معالي المحافظ	

3. السياسة



رمز السياسة	مالك السياسة	اسم السياسة
RI-06-P-002	مكتب إدارة البيانات	سياسة حماية البيانات الشخصية والخصوصية
هدف السياسة		
الغرض من هذه السياسة هو تمكين منسوبي الهيئة من الاطلاع على التزامات حماية البيانات الشخصية التنظيمية وتحديد وسائل وتدابير محددة لحماية البيانات الشخصية التي يتم جمعها ومعالجتها وتخزينها وإدارتها من قبل هيئة الزكاة والضريبة والجمارك.		
نطاق السياسة		
يتمثل نطاق هذه السياسة في ضمان حماية جميع البيانات الشخصية التي تتم معالجتها بواسطة هيئة الزكاة والضريبة والجمارك وفقاً للأنظمة واللوائح والسياسات ذات العلاقة. تنطبق هذه السياسة على كافة عمليات معالجة البيانات الشخصية التي تقوم بها هيئة الزكاة والضريبة والجمارك وكافة منسوبيها. وفي حال وجود أي تعارض بين ما ورد في هذه السياسة والأنظمة واللوائح والسياسات ذات العلاقة، يجب أن تحل الأنظمة واللوائح والسياسات الصادرة من الجهات المختصة في المملكة دائماً محل هذه السياسة.		
فترة سريان السياسة		
تكون السياسة سارية ما لم يرد أي توجيه رسمي بتحديثها أو إلغاؤها		

4. المصطلحات والتعاريف



المصطلح	التعريف
الهيئة	هيئة الزكاة والضريبة والجمارك
المجلس	مجلس إدارة هيئة الزكاة والضريبة والجمارك
المحافظ	محافظ هيئة الزكاة والضريبة والجمارك
الجهة المختصة	الجهة التي يصدر بتحديد قرار من مجلس الوزراء.
البيانات الشخصية	كل بيان - مهما كان مصدره أو شكله - من شأنه أن يؤدي إلى معرفة الفرد على وجه التحديد، أو يجعل التعرف عليه ممكناً بصفة مباشرة أو غير مباشرة، ومن ذلك: الاسم، ورقم الهوية الشخصية، والعناوين، وأرقام التواصل، وأرقام الرخص والسجلات والممتلكات الشخصية، وأرقام الحسابات البنكية والبطاقات الائتمانية، وصور الفرد الثابتة أو المتحركة، وغير ذلك من البيانات ذات الطابع الشخصي.
المعالجة	أي عملية تجرى على البيانات الشخصية بأي وسيلة كانت يدوية أو آلية، ومن ذلك: عمليات الجمع، والتسجيل، والحفظ، والفهرسة، والترتيب، والتنسيق، والتخزين، والتعديل، والتحديث، والدمج، والاسترجاع، والاستعمال، والافصاح، والنقل، والنشر، والمشاركة في البيانات أو الربط البيني، والحجب والمسح والإتلاف.
الجمع	حصول جهة التحكم على البيانات الشخصية وفقاً لأحكام النظام، سواء من صاحبها مباشرة أو ممن يمثله أو ممن له الولاية الشرعية عليه أو من طرف آخر.
الإتلاف	أي إجراء يتم على البيانات الشخصية ويجعل من المتعذر الاطلاع عليها أو استعادتها مرة أخرى أو معرفة صاحبها على وجه التحديد.
الإفصاح	تمكين أي شخص - عدا جهة التحكم أو جهة المعالجة بحسب الأحوال - من الحصول على البيانات الشخصية أو استعمالها أو الاطلاع عليها بأي وسيلة ولأي غرض.
النقل	نقل البيانات الشخصية من مكان إلى آخر لمعالجتها.
النشر	بث أي من البيانات الشخصية عبر وسيلة نشر مقروءة أو مسموعة أو مرئية، أو إتاحتها.
البيانات الحساسة	كل بيان شخصي يتضمن الإشارة إلى أصل الفرد العرقي أو أصله القبلي، أو معتقده الديني أو الفكري أو السياسي، أو يدل على عضويته في جمعيات أو مؤسسات أهلية. وكذلك البيانات الجنائية والأمنية، أو بيانات السمات الحيوية التي تحدد الهوية، أو البيانات الوراثية، أو البيانات الائتمانية، أو البيانات الصحية، وبيانات تحديد الموقع، والبيانات التي تدل على أن الفرد مجهول الأبوين أو أحدهما.
البيانات الصحية	كل بيان شخصي يتعلق بحالة الفرد الصحية، سواء الجسدية أو العقلية أو النفسية أو المتعلقة بالخدمات الصحية الخاصة به.

المصطلح	التعريف
الخدمات الصحية	الخدمات المتعلقة بصحة الفرد، ومن ذلك الخدمات الوقائية والعلاجية والتأهيلية والتنويم وتوفير الدواء.
البيانات الائتمانية	كل بيان شخصي يتعلق بطلب الفرد الحصول على تمويل، أو حصوله عليه، سواء لغرض شخصي أو عائلي، من جهة تُمارس التمويل، بما في ذلك أي بيان يتعلق بقدرته على الحصول على ائتمان أو بقدرته على الوفاء به أو بتاريخه الائتماني.
صاحب البيانات الشخصية	الفرد الذي تتعلق به البيانات الشخصية.
الجهة العامة	أي وزارة أو مصلحة أو مؤسسة عامة أو هيئة عامة، أو أي جهة عامة مستقلة في المملكة، أو أي من الجهات التابعة لها.
جهة التحكم	أي جهة عامة، وأي شخصية ذات صفة طبيعية أو اعتبارية خاصة؛ تحدد الغرض من معالجة البيانات الشخصية وكيفية ذلك؛ سواء تمت معالجة البيانات بوساطتها أم بوساطة جهة المعالجة.
جهة المعالجة	أي جهة عامة، وأي شخصية ذات صفة طبيعية أو اعتبارية خاصة؛ تعالج البيانات الشخصية لمصلحة جهة التحكم نيابةً عنها.
الطفل	كل شخص لم يتجاوز الثامنة عشرة من عمره.
الأهلية	صلاحية الشخص لصدور التصرفات منه على وجه يعتد به شرعا ونظاما.
فاقد الأهلية	من ليس لديه أهلية كالصغير غير المميز - وهو من لم يكمل السابعة من عمره - والمجنون، والمعتوه، وفاقدا الإدراك ونحوهم.
ناقص الأهلية	من لديه أهلية غير مكتملة كالصغير المميز - وهو من أكمل السابعة ولم يتم الثامنة عشرة من العمر - وذوي الغفلة، والسفيه، ومن به عاهة عقلية، ونحوهم.
الولي	أحد الوالدين أو من تكون له الولاية على شؤون الطفل حسب أحكام الشريعة أو الأنظمة ذات العلاقة.
الولاية	سلطة يثبتها الشرع للولي تخوله صالحة التصرف وإدارة شؤون الطفل نيابة عنه فيما يتعلق ببدنه ونفسه.

5. بنود السياسة



5.1 حقوق أصحاب البيانات الشخصية

أ. يحق لصاحب البيانات الشخصية التالي:

1. الحق في العلم، ويشمل ذلك إحاطته علماً بالمسوغ النظامي أو العملي المعتبر لجمع بياناته الشخصية، والغرض من ذلك، وألاً تعالج بياناته لاحقاً بصورة تتنافى مع الغرض من جمعها.
2. الحق في وصوله إلى بياناته الشخصية المتوافرة لدى الهيئة، ويشمل ذلك الاطلاع عليها، والحصول على نسخة منها بصيغة واضحة ومطابقة لمضمون السجلات وذلك دون إخلال بما تقضي به هذه السياسة.
3. الحق في طلب تصحيح بياناته الشخصية المتوافرة لدى الهيئة، أو إتمامها، أو تحديثها.
4. الحق في طلب إتلاف بياناته الشخصية المتوافرة لدى الهيئة مما انتهت الحاجة إليه منها، وذلك دون إخلال بما تقضي به هذه السياسة.

ب. تمكين حقوق أصحاب البيانات الشخصية:

1. قبل أو عند جمع البيانات الشخصية مباشرةً من صاحب البيانات الشخصية، يجب أن تتخذ الهيئة التدابير المناسبة لإبلاغ صاحب البيانات الشخصية بما يلي:
 - أ. المسوغ النظامي أو العملي المعتبر لجمع بياناته الشخصية.
 - ب. الغرض من جمع بياناته الشخصية، وما إذا كان جمعها كلها أو بعضها إلزامياً أم اختيارياً، والآثار والأخطار المحتملة التي تترتب على عدم إتمام إجراء جمع البيانات الشخصية.
 - ج. أن تكون معالجة البيانات الشخصية عند جمعها أو (لاحقاً بعد جمعها) لا تتنافى مع الغرض الذي جمعت من أجله. ويجب أن تكون مناسبة ومقتصرة على الحد الأدنى الضروري لتحقيق الغرض من الجمع. وبمجرد تحقيق الغرض من الجمع يجب تجنب المحتوى الذي قد يؤدي إلى تحديد صاحب البيانات الشخصية.
 - د. تحديد وإشعار صاحب البيانات الشخصية بهوية من يجمع البيانات الشخصية وعنوان مرجعه عند الاقتضاء، ما لم يكن جمعها لأغراض أمنية.
 - هـ. تحديد وإشعار صاحب البيانات الشخصية بالجهة أو الجهات التي سيُجرى إفصاح البيانات الشخصية إليها، وصفتها، وما إذا كانت البيانات الشخصية ستُنقل أو سيفصح عنها أو ستعالج خارج المملكة.

- و. إبلاغ صاحب البيانات الشخصية بحقوقه.
- ز. يجب ألا تتعارض طرق ووسائل الجمع مع أي أحكام نظامية، وأن تكون مناسبة لظروف صاحب البيانات الشخصية، وأن تكون مباشرة وواضحة وآمنة، ولا تنطوي على أي خداع أو تضليل أو ابتزاز.
- ح. يجب أن تحدد الهيئة الإجراءات التي تضمن أن أي شخص يعالج البيانات الشخصية يلتزم بالضوابط والسياسات والتوجيهات والأحكام الأخرى والأنظمة الصادرة لحماية سرية البيانات الشخصية حتى بعد انتهاء العلاقة المهنية أو التعاقدية لهذا الشخص.
- ط. يجوز للهيئة جمع البيانات الشخصية من غير صاحب البيانات الشخصية، كمصدر، ومعالجتها بحسب الأنظمة واللوائح المعمول بها في المملكة.
- ي. لا يجوز تصوير الوثائق الرسمية التي تحدد هوية صاحب البيانات الشخصية أو نسخها، إلا عندما يكون ذلك تنفيذاً لأحكام نظام، أو عندما تطلب جهة عامة مختصة تصوير تلك الوثائق أو نسخها وفق ما تحدده اللوائح والأنظمة المعمول بها في المملكة.
- ك. فيما عدا المواد التوعوية التي ترسلها الجهات العامة، لا يجوز للهيئة استخدام وسائل الاتصال الشخصية -بما فيها عناوين البريدية والإلكترونية- الخاصة بصاحب البيانات الشخصية لأجل إرسال مواد دعائية أو توعوية، إلا وفقاً لما يأتي:
1. أن تؤخذ موافقة المتلقي المستهدف على إرسال هذه المواد إليه.
 2. أن يوفر مرسل المواد آلية واضحة تمكن المتلقي المستهدف من إبداء رغبته في التوقف عن إرسالها.
2. للهيئة أن تحد من ممارسة حقوق صاحب البيانات في الحالات التالية:
- أ. إذا كان جمع البيانات الشخصية أو معالجتها ضرورياً لحماية الصحة أو السلامة العامة أو حماية حياة فرد أو أفراد معينين أو حماية صحتهم.
- ب. إذا كان التقييد مطلوباً لأغراض أمنية أو بحسب ما يقتضيه نظام آخر أو استيفاء لمتطلبات قضائية.
3. يجب على الهيئة إشعار الجهات ذات الصلة التي تمت مشاركة البيانات معها وإتاحة التعديل لهذه الجهات عند تحديث البيانات الشخصية أو تصحيحها.
4. يجب أن تستجيب الهيئة لطلبات أصحاب البيانات الشخصية المتعلقة بحقوقهم خلال فترة محدد وإجراء واضح.
5. إذا كان هناك سبب نظامي يتطلب الاحتفاظ بالبيانات الشخصية لفترة محددة، فيجب الاحتفاظ بالبيانات حتى تنتهي فترة الاحتفاظ أو يتم تحقيق الغرض من جمعها، أيهما يستغرق وقتاً أطول.

6. إذا كانت البيانات الشخصية مرتبطة بقضية منظورة أمام جهة قضائية، فيجب إتلاف البيانات بعد تحقيق الغرض من الاحتفاظ بها واستكمال الإجراءات القضائية المرتبطة بها.

7. يجب على الهيئة إتلاف البيانات الشخصية فور انتهاء الغرض من جمعها. ومع ذلك، يجوز لها الاحتفاظ بتلك البيانات بعد انتهاء الغرض من جمعها إذا تمت إزالة كل ما يؤدي إلى معرفة صاحبها على وجه التحديد.

8. يمكن للهيئة جمع البيانات الشخصية أو مُعالجتها لأغراض علمية أو بحثية أو إحصائية دون موافقة صاحبها، في الأحوال التالية:

- أ. إذا لم تتضمن البيانات الشخصية ما يدل على هوية صاحبها على وجه التحديد.
- ب. إذا كان سيُتم إتلاف ما يدل على هوية صاحب البيانات الشخصية على وجه التحديد خلال عملية مُعالجتها وقبل الإفصاح عنها لأي جهة أخرى ما لم تكن تلك البيانات، بيانات حساسة.
- ج. إذا كان جمع البيانات الشخصية أو مُعالجتها لهذه الأغراض يقتضيها نظام آخر أو تنفيذاً لاتفاق سابق يكون صاحبها طرفاً فيه.

ج. الخصوصية وإدارة الموافقات:

1. يجب أن ينقل إشعار الخصوصية المعروض للمستخدم الحد الأدنى من المعلومات التالية:

- أ. الغرض من جمع ومحتوى البيانات الشخصية التي تم جمعها.
- ب. وسائل الجمع والمعالجة والتخزين والمشاركة والإتلاف.
- ج. حقوق صاحب البيانات الشخصية وتفاصيل الاتصال بالهيئة لأي استفسارات حول معالجة البيانات الشخصية.

2. يجب أن تتبع معالجة البيانات الشخصية سياسات الإقرار المذكورة في هذه الفقرة في جميع الحالات، باستثناء ما يلي:

- أ. إذا حققت المعالجة مصلحة محددة لصاحب البيانات ولكن لا يمكن الوصول إليه.
- ب. إذا كانت معالجة البيانات تتوافق مع نظام آخر أو اتفاقية سابقة كان صاحب البيانات جزءاً منها.
- ج. إذا كان مطلوب من الهيئة معالجة البيانات الشخصية لأغراض أمنية أو لمتطلبات قضائية.

د. إذا كانت المعالجة ضرورية لغرض المصلحة المشروعة للهيئة، دون المساس بحقوق ومصالح صاحب البيانات الشخصية، وبشرط عدم معالجة أي بيانات حساسة.

3. يجب أن تضمن الهيئة أن الموافقة الممنوحة من صاحب البيانات الشخصية قد لا تشكل شرطاً لتقديم خدمة أو ميزة ما لم تكن هذه الخدمة أو الميزة مرتبطة بشكل مباشر بمعالجة البيانات الشخصية التي تم منح الموافقة عليها.

4. فيما عدا البيانات الحساسة، يمكن معالجة البيانات الشخصية لأغراض تسويقية، إذا تم جمعها مباشرة من صاحب البيانات الشخصية وتم منح موافقته.

5.2 البيانات الائتمانية والصحية:

أ. البيانات الائتمانية والصحية:

1. يجب أن تطبق الهيئة ضوابط وتدابير تنظيمية وتقنية وإدارية مناسبة لحماية البيانات الصحية وضمان سريتها وسلامتها، بما في ذلك:
 - أ. قصر الحق في الوصول إلى البيانات الصحية، بما في ذلك الملفات الطبية، على الحد الأدنى من عدد الموظفين أو العاملين عليها فقط القدر اللازم لتقديم الخدمات الصحية المطلوبة.
 - ب. تقييد إجراءات معالجة البيانات الصحية إلى الحد الأدنى الممكن للموظفين العاملين عليها لتقديم الخدمات الصحية أو تقديم برامج التأمين الصحي.
 - ج. تنفيذ التدابير المناسبة للتحقق من أن صاحب البيانات الشخصية قد أعطى موافقته الصريحة على جمع البيانات الشخصية المتعلقة بالمعلومات الائتمانية، أو تغيير الغرض من جمع البيانات الشخصية أو الكشف عنها أو نشرها.
 - د. وجوب اشعار صاحب البيانات الشخصية عند استلام طلب الإفصاح عن بياناته الائتمانية من أي جهة.

5.3 الاطفال ومن في حكمهم:

بالإضافة إلى البنود أعلاه، يجب أن تلتزم جميع البيانات الشخصية للأطفال ومن في حكمهم بالتالي:

1. يجب إبلاغ الوصي النظامي إذا قامت الهيئة بجمع أي بيانات شخصية إضافية من مصادر أخرى.
2. يجب إبلاغ الوصي النظامي بكيفية معالجة واستخدام البيانات الشخصية للأطفال أو من في حكمهم، بما في ذلك الغرض من الجمع وخيار ممارسة حقوقهم.
3. يجب أن تتحقق الهيئة من هوية الأوصياء النظاميين قبل منح أي وصول، والحصول على موافقة منهم قبل أي محاولة للاتصال بالأطفال أو من في حكمهم أو جمع أي بيانات شخصية منهم.
4. يجب استخدام أي معلومات اتصال خاصة بالوصي النظامي أو الأطفال أو من في حكمهم فقط للرد المباشر على طلبات الأطفال أو من في حكمهم أو سلامتهم. علاوة على ذلك، لا يجوز استخدامها لأي أسباب أخرى، أو الكشف عنها أو دمجها مع بيانات أخرى.

5. يجب أن تستند البيانات الشخصية للوصي النظامي، التي يتم جمعها من الأطفال أو من في حكمهم، إلى مبدأ تقليل البيانات، ويجب استخدامها فقط للاتصال بالوصي النظامي لأغراض الموافقة.

6. لا يجوز للهيئة تنفيذ أي قرار آلي بناءً على البيانات الشخصية للأطفال أو من في حكمهم، مثل الإعلانات المستهدفة.

7. لا يجوز مشاركة البيانات الشخصية للأطفال أو من في حكمهم إلا مع أطراف أخرى للأغراض التي تسمح بها الأنظمة واللوائح المعمول بها في المملكة. ويجب إشعار الأطراف الثالثة الذين تتم مشاركة البيانات الشخصية، للأطفال أو من في حكمهم، معهم بالسياسات المعمول بها بشكل كافٍ.

5.4 معالجة البيانات وشفافية المخاطر:

أ. سجل أنشطة معالجة البيانات:

1. تحتفظ الهيئة بسجل لأنشطة معالجة البيانات الشخصية. وأدناه هي الحد الأدنى لمتطلبات بيانات السجل:

أ. تفاصيل الاتصال بالهيئة.

ب. الغرض من معالجة البيانات الشخصية ومدة الاحتفاظ بهذه البيانات.

ج. فئات وأوصاف أصحاب البيانات الشخصية.

د. الجهات داخل المملكة أو خارجها والتي سيتم الكشف لها عن البيانات الشخصية ونقلها إليها.

ب. تقييم تأثير خصوصية البيانات:

1. تقوم الهيئة بتقييم المخاطر والآثار المحتملة لأنشطة معالجة البيانات الشخصية.

5.5 حوكمة البيانات الشخصية:

أ. الإفصاح عن البيانات الشخصية:

1. يجب على الهيئة الإفصاح عن البيانات الشخصية فقط في الحالات التالية:

أ. إقرار أصحاب البيانات الشخصية على الإفصاح.

ب. إذا تم جمع البيانات الشخصية من مصدر متاح للعامة.

ج. إذا كان الإفصاح سيقتصر على معالجتها لاحقاً بطريقة لا تؤدي إلى معرفة هوية صاحب البيانات الشخصية أو أي فرد آخر على وجه التحديد.

د. - إذا كان الإفصاح ضرورياً لتحقيق مصالح مشروعة لجهة التحكم، ما لم يخل ذلك بحقوق صاحب البيانات الشخصية أو يتعارض مع مصالحه ولم تكن تلك البيانات بيانات حساسة..

ه. إذا كان الإفصاح ضرورياً لحماية الصحة أو السلامة العامة أو حماية حياة فرد أو أفراد معينين أو حماية صحتهم.

2. لا يجوز للهيئة الإفصاح عن البيانات الشخصية في البنود المذكورة في الفقرات (1، 2، 3، 4) من بيان السياسة أعلاه إلا إذا كان الإفصاح:

أ. يمثل خطراً على الأمن، أو يسبب إلى سمعة المملكة، أو يتعارض مع مصالحها.

ب. يؤثر على علاقات المملكة مع دولة أخرى.

ج. يمنع من كشف جريمة أو يمس حقوق متهم في الحصول على محاكمة عادلة أو يؤثر في سلامة إجراءات جنائية قائمة.

د. يعرض سلامة فرد أو أفراد للخطر.

ه. يترتب عليه انتهاك خصوصية فرد آخر غير صاحب البيانات الشخصية.

و. يتعارض مع مصلحة ناقص أو عديم الأهلية.

ز. الإخلال بالتزامات المهنية المقررة نظاماً.

ح. ينطوي عليه إخلال بالتزام أو إجراء أو حكم قضائي.

ط. يكشف عن مصدر سري لمعلومات تحتم المصلحة العامة عدم الكشف عنه

ب. نقل البيانات الشخصية خارج المملكة:

1. لا يجوز للهيئة نقل البيانات الشخصية إلى خارج المملكة أو الإفصاح عنها لجهة خارج المملكة إلا إذا كان ذلك تنفيذاً للالتزام بموجب اتفاقية تكون المملكة طرفاً فيها، أو لخدمة مصالح المملكة، أو لأغراض أخرى وفقاً لما تحدده الأنظمة واللوائح المعمول بها في المملكة ووفقاً للشروط التالية:

أ. ألا يترتب على النقل أو الإفصاح مساس بالأمن الوطني أو بمصالح المملكة الحيوية.

ب. أن تقدم ضمانات كافية للمحافظة على البيانات الشخصية التي سيُجرى نقلها أو الإفصاح عنها وعلى سريتها، بحيث لا تقل معايير حماية البيانات الشخصية عن المعايير الواردة في الأنظمة واللوائح المعمول بها في المملكة.

ج. أن يقتصر النقل أو الإفصاح على الحد الأدنى من البيانات الشخصية الذي تدعو الحاجة إليه.

د. موافقة الجهة المختصة على النقل أو الإفصاح.

ه. وفيما عدا الشرط الوارد في الفقرة (5.ب.1.أ)، يجوز للجهة المختصة أن تعفي الهيئة -في كل حالة على حدة- من الالتزام بأحد الشروط المشار إليها؛ متى قَدَّرت الجهة المختصة منفردة أو بالاشتراك مع جهات أخرى أن البيانات الشخصية سيتوافر لها مستوى مقبول من الحماية خارج المملكة، ولم تكن تلك البيانات بيانات حساسة.

ج. العقود بين الهيئة والمعالجين والعقود اللاحقة:

1. لا تتعاقد الهيئة إلا مع المعالجين الذين يقدمون الضمانات اللازمة لتنفيذ أحكام هذه السياسة والأنظمة واللوائح المعمول بها بالمملكة ويضمنون الالتزام بمراقبة معالجة البيانات الشخصية.

د. ادارة الحوادث وتسرب البيانات الشخصية:

1. يجب على الإدارة العامة للأمن المعلوماتي السيبراني إبلاغ إدارة حماية البيانات والخصوصية بمجرد اكتشاف أي حادث مرتبط بالبيانات الشخصية.
2. يجب على الهيئة أن تبدأ، وتدير، وتحافظ على عملية إدارة شاملة للحوادث وتسرب البيانات الشخصية وفقاً لإطار عمل إدارة حوادث الأمن السيبراني.
3. يجب على الهيئة إشعار صاحب البيانات الشخصية بأي تسرب أو ضرر أو وصول غير مصرح به لبياناتهم الشخصية من شأنه أن يتسبب في تلف بياناتهم أو يتسبب في الإضرار بحقوقهم ومصالحهم.
4. يجب ان تشعر الهيئة الجهة المختصة عند علمها بأي حادث تسرب أو ضرر أو وصول غير مصرح به إلى البيانات الشخصية بما لا يتجاوز 72 ساعة من علمها.

5.6 الادوار والمسؤوليات:

- أ. مكتب إدارة البيانات هي المسؤولة عن صحة ما ورد في هذه السياسة.
- ب. يجب على الهيئة تعيين مسؤول حماية البيانات الشخصية-أو أكثر- لتنفيذ الضوابط التي تضمن الامتثال للأنظمة واللوائح ذات الصلة.
- ج. يجب على جميع الموظفين والمقاولين والمتعاقدين والأطراف الثالثة المتعاملين مع الهيئة الالتزام بهذه السياسة.
- د. يجب إجراء مراجعة للسياسة سنوياً على الأقل للتأكد من أن هذه السياسة محدثة.
- هـ. يجب إبلاغ أوجه القصور للامتثال للسياسة على الفور إلى مسؤول حماية البيانات الشخصية وأي تغييرات في السياسة تتطلب موافقة إدارة حماية البيانات الشخصية والخصوصية واللجنة التوجيهية للأمن السيبراني وإدارة البيانات.
- و. يجب تحديث سجل التغيير ليعكس أي تغييرات معتمدة في السياسة.

5.7 مراقبة الامتثال للسياسات:

- أ. يشرف مكتب إدارة البيانات واللجنة التوجيهية للأمن السيبراني وحوكمة البيانات على الامتثال لبيان هذه السياسة. وستؤدي أي مخالفة لها إلى اتخاذ إجراءات تأديبية وفقاً لإجراءات الهيئة.

- ب. يجب على كافة منسوبي الهيئة الالتزام بهذه السياسة، وعلى جميع المدراء في الهيئة ضمان مراقبة الالتزام بشكل مستمر في إدارتهم.
- ج. تتعاون الهيئة مع الجهات المختصة في أداء مهامها في الإشراف على تنفيذ أحكام النظام واللائحة واتخاذ الإجراءات اللازمة التي تحال إليها الهيئة من قبل الجهات المختصة.

5.8 الاستثناءات من السياسة:

- أ. يجب اعتماد جميع الاستثناءات لهذه السياسة من قبل مكتب إدارة البيانات واللجنة التوجيهية للأمن السيبراني وحوكمة البيانات. ويكون الاستثناء ساري المفعول لفترة ثلاث شهور من تاريخ اعتماده ثم يجب إعادة تقييمه واعتماده عند الضرورة.
- ب. تهدف هذه السياسة إلى معالجة حماية البيانات الشخصية، فإذا لزم الأمر للاستثناء، يجب تقديم طلبات الاستثناء رسميًا إلى مكتب إدارة البيانات، بما في ذلك التبرير والفوائد المنسوبة إلى طلب الاستثناء.

6. آلية إدارة تحديثات السياسة



6.1 المراجعة الدورية

يتم مراجعة السياسة بشكل سنوي او حسب الحاجة للتعديل لأي تغييرات قد تطرأ على اعمال الهيئة، ويكون مدير إدارة السياسات المؤسسية واتفاقيات مستوى الخدمة مسؤولاً عن التنسيق مع مدراء الإدارات المعنية بالسياسة عن تسهيل عملية إجراء المراجعة الدورية المنتظمة لهذا المستند.

7. المراجع



اسم الوثيقة	نوع المرجع
نظام حماية البيانات الشخصية الصادر بالمرسوم الملكي رقم (م/148) وتاريخ 1444/09/05هـ ولائحته التنفيذية المعتمدة.	نظام
سياسة حماية البيانات الشخصية - مكتب إدارة البيانات الوطنية	سياسة
سياسة حماية البيانات الشخصية للأطفال ومن في حكمهم - مكتب إدارة البيانات الوطنية.	سياسة
القواعد العامة لنقل البيانات الشخصية خارج الحدود الجغرافية - مكتب إدارة البيانات الوطنية.	قواعد
الضوابط الأساسية للأمن السيبراني (ECC - 1: 2018) - الهيئة الوطنية للأمن السيبراني.	ضوابط
ISO 27001:2013: متطلبات نظام إدارة أمن المعلومات	مواصفة قياسية دولية
ISO 27002: مدونة قواعد الممارسة لإدارة أمن المعلومات.	مواصفة قياسية دولية
ISO/IEC 27701 إدارة معلومات الخصوصية	مواصفة قياسية دولية
ضوابط ومواصفات إدارة البيانات الوطنية وحوكمتها وحماية البيانات - مكتب إدارة البيانات الوطنية.	ضوابط ومواصفات قياسية محلية
مدونة قواعد السلوك الوظيفي وأخلاقيات الوظيفة العامة - هيئة الزكاة والضريبة والجمارك	قواعد

